

-
File No: EXP202300944
-

RESOLUTION OF TERMINATION OF THE PROCEDURE BY VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On March 7, 2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against CAIXABANK, S.A. (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No: EXP202300944

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on December 7, 2022. The complaint is directed against CAIXABANK, S.A. with NIF A08663619 (hereinafter, CAIXABANK). The reasons on which the complaint is based are as follows: The complainant states that CAIXABANK has requested a series of data from him, in accordance with the provisions of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism.

He adds that the information collected is reflected in a document called "Declaration/Modification of data for the business relationship (Model 5433)," but before signing the form (which contains his personal and economic data), he checks that, in the wording of one of the clauses, it indicates that he expressly consents to CAIXABANK requesting his data from the General Treasury of the Social Security, without being given the option to express his refusal in this regard, so the consent is already pre-established.

In this context, he indicates that after expressing his disagreement regarding this, CAIXABANK informs him that the process followed by them was a routine process applied equally to all clients and that, if he did not sign under those conditions, his bank account would be blocked.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

And, he provides the following relevant documentation:

Screenshot related to his personal area, indicating that the document "Model 5433 Economic Activity" is pending signature.

Copy of the aforementioned document (Model 5433) in which, among other things, it states the following:

"6. The declarant states that he has been informed by CaixaBank that the current legislation on the prevention of money laundering requires banking entities to obtain from their clients information about their economic activity and to carry out a verification of it. For this exclusive purpose of verifying the information provided, he gives his express consent to CaixaBank to request this information from the General Treasury of the Social Security on his behalf. The data obtained from the General Treasury of the Social Security will be used exclusively for the management indicated above. In the event of non-compliance with this obligation by CaixaBank and/or the personnel providing services therein, all actions provided for in Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights will be executed."

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights (hereinafter LOPDGDD), the complaint was forwarded to

CAIXABANK, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements established in the data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on January 30, 2023, as evidenced by the acknowledgment of receipt in the file.

On March 9, 2023, a response was received in this Agency indicating:

1. That CAIXABANK is obliged to obtain information about the purpose and nature of the business relationship and to carry out continuous monitoring of that relationship according to Law 10/2010, of April 28, on the Prevention of Money Laundering and the Financing of Terrorism (hereinafter "LPBCFT"), and its Regulation (Regulation of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism, hereinafter, "RLPBCFT").

And it refers to the following wording:

"Article 11 RLPBCFT. Continuous monitoring of the business relationship.

1. The obligated subjects shall scrutinize the operations carried out throughout the business relationship to ensure that they correspond with the professional or business activity of the client, and with their operational background [...]"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/26

That in order to carry out said "scrutiny," the LPBCFT expressly obliges and enables the collection of information from its clients in order to understand the nature of their professional or business activity and to adopt measures that allow for a reasonable verification of the truthfulness of the information:

"Article 5 LPBCFT. Purpose and nature of the business relationship.

The obligated subjects shall obtain information regarding the intended purpose and nature of the business relationship. In particular, the obligated subjects shall collect information from their clients in order to understand the nature of their professional or business activity and shall adopt measures aimed at reasonably verifying the truthfulness of such information. Such measures shall consist of the establishment and application of verification procedures for the activities declared by the clients. (,,)"

2. That this mandate is reflected in the document Model 5433 "Declaration/Modification of data for the business relationship" where data, specifically socioeconomic data, is collected, and it is informed that CAIXABANK has the obligation to verify the data provided.

3. That "As can be seen, the processing of the claimant's data by this entity (collection of necessary data for the monitoring of the relationship and mandatory verification or checking) is carried out in strict compliance with the applicable regulations."

4. In relation to the blocking of accounts, it refers to, among other information, that:

a. According to Article 7.3 LPBCFT: "the obligated subjects shall not establish business relationships, nor execute operations when they cannot apply the due diligence measures provided by law, terminating the business relationship when they cannot apply such measures."

At the same time, it also determines: "that the refusal of the entities to establish business relationships or to execute operations or the termination of the relationship due to the inability to apply due diligence measures shall not entail, unless there is unjust enrichment, any type of liability for the entity."

b. That in section 4 of model 5433 it is stated that:

"4. The declarant states that the data recorded is theirs and complete and acknowledges that the inaccuracy or lack of truthfulness of the same and/or in the documents provided (accuracy or truthfulness that CaixaBank reserves the right to verify by its own means), as well as the breach of the commitments made under it may be sufficient cause for the denial by CaixaBank and/or the companies of the CaixaBank group of the establishment of the business relationship or the contracting of any product or service and shall empower CaixaBank and/or any of the companies of the CaixaBank group to suspend and, even, terminate the business relationship that, if applicable, has been established."

c. It states:

"As you can see, the eventual termination of the business relationship arises from the inaction of the

client regarding the provision of those legally required data and/or from the lack of mandatory verification or checking of the same.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
4/26

In no case, contrary to what the claimant has stated -without any evidentiary activity justifying such an assertion- does the absence of consent for the verification of the (necessary) data provided for the understanding of the business relationship, through consultation of the TGSS database (as reported in section 6 of Model 5433), or its timely revocation, imply or may imply the termination of the business relationship with CaixaBank, whose actions in the area of money laundering prevention strictly adhere to the LPBCFT and the RLPBCFT.

5. It is noted that there is no record of any claim by the claimant in their systems. It is understood that the claimant is exercising the right of revocation, and therefore they proceed to register this revocation in their systems, with immediate effect. A copy of a letter dated 08/03/2023 addressed to the claimant is provided, informing them that they have proceeded with the revocation of their consent for data consultation with the TGSS.

THIRD: On March 7, 2023, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claimant was admitted for processing.

FOURTH: The General Subdirector of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

1. The "Know Your Customer" process (hereinafter KYC) is the process by which CaixaBank complies with the due diligence obligations established by the LPBCFT, obligations that involve the identification of the customer and obtaining information related to their professional activity, including the obligation to reasonably verify the activity in the case of customers with a higher-than-average risk, as well as ensuring that in all cases the information remains updated through review processes.

For all these reasons, such a process is carried out:

- At the time of onboarding a customer at the entity.
- Periodically, for the updating of information. (...)

2. There is a collaboration agreement between the General Treasury of the Social Security (hereinafter, TGSS), the Spanish Banking Association, the Spanish Confederation of Savings Banks, and the National Union of Credit Cooperatives regarding the transfer of information, whose sole objective is to allow financial entities to consult certain information about their customers in order to verify it and comply with the due diligence measures established by the LPBCFT. CaixaBank adhered to this agreement (...).

In its sixth clause ("Responsibility for the operation of the SVFI"), it is stated:

"(...) Likewise, each Collaborating Financial Entity undertakes to ensure, regarding each request it makes:

- a) That the requests refer to individuals who are initiating business relationships with the Financial Entity or to individuals for whom, after a reasonable time, it is necessary to update their information.
 - b) That prior to the request for information by the Collaborating Financial Entity, it has the corresponding express authorization, signed by the interested party, and agreed upon by the parties. (See Annex III).
 - c) That it commits to safeguard the authorizations from the clients. Due to control or audit actions carried out by the TGSS as the data holder, Financial Entities are obliged to provide the documentation in their possession within a period not exceeding ten calendar days from the request. This same period will also apply to requests that, if applicable, may be made by the Data Protection Agency.
- (...)"

The content of Annex III of the aforementioned agreement has the following content:

3. In the processes of onboarding new clients, all personal data information provided by them is consolidated in the "Framework Contract," which the new client must sign.

The process of onboarding new clients that CAIXABANK established after its adherence to the agreement (...) was modified on the following dates:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/26

- In office: In May 2023.

- In digital banking (CaixaBankNow) and mobile banking (app): In June 2023.

Therefore, in such a process of onboarding new clients, there are differences depending on the time period in which it was carried out:

a) From CaixaBank's adherence to the agreement (...) until the modifications of the onboarding process for new clients made in the year 2023:

(i) In the framework contract model, the following is stated:

"(...)

You declare that you have been informed by CaixaBank that the current legislation on the prevention of money laundering requires banking entities to obtain from their clients information about their economic activity and to verify the same. For the exclusive purpose of verifying the information provided, you give your express consent to CaixaBank to request this information from the General Treasury of the Social Security on your behalf. The data obtained from the General Treasury of the Social Security will be used exclusively for the management mentioned above (...).

[...]

4. PERSONAL DATA PROCESSING

[...]

4.4 Data processed

[...]

> Data that you have provided us during the onboarding of your contracts or during your relationship with us through interviews or forms. These are the types of data and the details of the data:

[...]

Data regarding your professional or labor activity and socioeconomic data: professional or labor activity, income or remuneration, family unit or circle, level of education, assets, tax data, and tax information.

[...]

> Data obtained from publicly accessible sources, public records, or external sources. These are the types of data and the details of the data:

[...]

4.5 What treatments we perform with your data.

The treatments we will carry out with your data are diverse and respond to different purposes and legal bases:

> Treatments based on consent for the purposes of:

- Personalization of the commercial offer through other channels.
- Data transfer to other companies.
- Identification of clients and signing of documentation using biometrics.
- Application of personal conditions in co-ownership contracts

[...]

> Treatments necessary to comply with regulatory obligations, mainly for the purpose of:

- Complying with the regulations on the prevention of money laundering and the financing of terrorism.
- Complying with tax regulations.
- Complying with obligations arising from international sanctions and financial countermeasures policies.

- Addressing complaints and claims.

[...]

(ii) In the onboarding processes for new clients, there is a process to grant or not grant consents exclusively in relation to the following treatments: "Personalization of the offer of products and services based on the analysis of your data," "Communication of the offer of products and services through channels," "Data transfer to other companies," "Applying personal conditions in co-ownership contracts."

(iii) The revocation of consents was done through a form, in the office.

(iv) That in the time period from the date 7/12/2021 until the dates indicated above when the onboarding processes for new clients of the year 2023 were implemented, they have completed the KYC onboarding process, signing the framework contract (...).

b) From the modifications of the onboarding process for new clients made in the year 2023:

(i) In the framework contract model, the following is stated:

5. PERSONAL DATA PROCESSING.

[...]

5.4 Data processed

[...]

Data that you have provided us during the onboarding of your contracts or during your relationship with us through interviews or forms. These are the types and details of the data:

[...]

- Data regarding your professional or labor activity and socioeconomic data: professional or labor activity, income or remuneration, family unit or circle, level of education, assets, tax data, and tax information.

[...]

Data obtained from publicly accessible sources, public records, or external sources. These are the types and details of the data:

[...]

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/26

- Data from the General Treasury of Social Security: identifying and contact data of the payer, data on professional or labor activity (CNAE, self-employed and/or employed worker, worker's contribution group).

[...]

5.5 What treatments we carry out with your data.

The treatments we will carry out with your data are diverse and respond to different purposes and legal bases:

Treatments based on consent, with the purposes of:

>

- Personalization of the offer of products and services according to the analysis of your data.
- Communication of the commercial offer through other channels.
- Transfer of data to other companies for the sending of commercial offers.
- Verification of economic activity to comply with regulations on the prevention of money laundering and the financing of terrorism.

[...]

Treatments necessary to comply with regulatory obligations,

>

mainly for the purpose of:

- Complying with regulations on the prevention of money laundering and the financing of terrorism.
- Complying with tax regulations.
- Complying with obligations arising from international sanctions and financial countermeasures

policies.

– Addressing complaints and claims.

[...]

(ii) In the KYC procedures for onboarding new clients, it is noted that consent for data verification with the TGSS can be granted or not granted both in the office, on the website www.caixabank.es, and in the entity's mobile application. It is also noted that consent can be revoked through the three previously mentioned channels.

4. In the processes of updating the personal data information of existing clients, the client must sign model 5433 (Declaration/Modification of data for the business relationship).

The process of updating the personal data information of existing clients that CAIXABANK established after its adherence to the agreement (...) was modified on the following dates:

- In the office: In February 2023.

- In digital banking (CaixaBankNow): In May 2023.

- In mobile banking (app): In June 2023.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/26

Therefore, in such a process of updating the personal data information of existing clients, there are differences depending on the time period in which it was carried out:

a) From CAIXABANK's adherence to the agreement (...) until the modifications of the process of updating the personal data information of existing clients made in 2023:

(i) In the "Declaration/Modification of data for the business relationship (Model 5433)", the following clauses are stated, which CAIXABANK indicates in its letter of November 30, 2023, is "The information regarding the data processing":

"5. Processing of personal data The data controller is CaixaBank, S.A., with NIF A-08663619 Contact details of the Data Protection Officer: www.CaixaBank.com/delegadoprotecciondedatos The requested data is necessary for the management and execution of the requested service and/or contract, and will be processed for that purpose; likewise, they will be processed to comply with the required regulatory obligations. This data may be communicated to authorities and public bodies, to comply with a legal obligation required, as well as to service providers and third parties necessary for the management and execution of the relationships derived from the service and/or contractual. The data will be processed as long as the relationships derived from the service and/or contractual established remain in force, and will be retained (for the statute of limitations of actions derived from such relationships) solely for the purpose of fulfilling the required legal obligations, and for the formulation, exercise, or defense of claims. Exercise of rights and claims before the Data Protection Authority The data subject may exercise their rights regarding their personal data in accordance with current regulations, at CaixaBank offices, at APARTADO DE CORREOS 209-46080 VALÈNCIA or at www.CaixaBank.com/ejerciciodederechos.

6. The declarant states that they have been informed by CaixaBank that current legislation on the prevention of money laundering requires banking entities to obtain from their clients information about their economic activity and to carry out a verification of the same. For this exclusive purpose of verifying the information provided, they give their express consent to CaixaBank to request from the General Treasury of Social Security such information on their behalf. The data obtained from the General Treasury of Social Security will be used exclusively for the management indicated above. In the event of non-compliance with this obligation by CaixaBank and/or the personnel providing services therein, all actions provided for in Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights will be executed."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

(ii) The revocation of such consent was made through a form, in-office.

(iii) That in the time period from the date 07/12/2021 until the dates previously indicated when the KYC processes of the year 2023 were initiated, they completed the KYC process for updating personal data information, (...).

b) Since the modifications to the process of updating the personal data of existing clients made in the year 2023:

(i) CAIXABANK, in its letter dated October 31, 2023, indicates:

- That the client must provide all the information that they already declared at the time of registration again.

- "Once all fields have been verified, a summary of the data will be shown to the client, and they must sign the updated or modified information, which is consolidated in document KYC 5433, which the client signs (...)."

In that "Declaration/Modification of data for the business relationship (Model 5433)," the same clauses are included as indicated by CAIXABANK in its letter dated November 30, 2023, except for clause 6.

"- If the client has not granted their consent to the verification of their economic activity, the client will be asked if they wish to provide their consent for the processing of their data for this purpose, (...)"

(ii) Consent can be revoked both in-office, on the website www.caixabank.es, and in the entity's mobile application.

FIFTH: According to the report collected from the AXESOR tool, the entity CAIXABANK, S.A. is a large company established in 1980, with a turnover of 1,310,563,000 euros in the year 2022.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of the GDPR, and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In accordance with the provisions of Article 4.2 of the GDPR, "processing" is understood as: any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or modification, extraction, consultation, use, communication by transmission, dissemination or any other form of enabling access, comparison or interconnection, limitation, erasure or destruction; In this case, according to the provisions of Article 4.2 of the GDPR, CAIXABANK is the one who processes the personal data of its clients, collecting their personal data and consulting it with the TGSS.

To this end, it establishes a procedure for obtaining information with personal data from clients and collecting consent to verify such personal data with the TGSS, through a form called "framework contract," for cases of new client registrations, and "model 5433 (Declaration/Modification of data for the business relationship)," for cases of updating the personal data of existing clients. Both documents are mandatory for subscription.

Therefore, in this procedure, the procedure established by CAIXABANK for obtaining the consent of CAIXABANK clients so that it can consult the personal data of these clients to verify the data obtained in accordance with the LPBCFT with the TGSS will be analyzed.

III

Article 6.1 of the GDPR

According to Article 6 of the GDPR "Lawfulness of processing:

1. Processing shall be lawful only if at least one of the following applies:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
 - b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
 - c) processing is necessary for compliance with a legal obligation to which the controller is subject;
 - d) processing is necessary to protect the vital interests of the data subject or of another natural person;
- 12/26

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) the processing is necessary for the purposes of legitimate interests pursued by the data controller or by a third party, provided that such interests do not override the interests or the fundamental rights and freedoms of the data subject which require the protection of personal data, particularly when the data subject is a child. The provisions of point f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions.”

In this case, CAIXABANK states that the verification of the personal data of its clients with the TGSS, obtained in compliance with the obligations imposed by the LPBCFT, is a consequence of the legal obligation imposed by Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism (LPBCFT), which outlines in its Article 2 the obligated subjects in the Prevention of Money Laundering: Financial Entities (banks, savings banks, credit cooperatives, etc.), Insurance Companies, Credit Entities, etc.

In this regard, this same law regulates in its Article 5 that “the obligated subjects shall obtain information from their clients in order to understand the nature of their professional or business activity and shall adopt measures aimed at reasonably verifying the truthfulness of such information.

Such measures shall consist of the establishment and application of verification procedures for the activities declared by the clients. These procedures shall take into account the different level of risk and shall be based on obtaining from clients documents related to the declared activity or obtaining information about it from sources other than the client.” (the underlining is ours)

Adding in its Article 6 that “The obligated subjects shall apply measures of continuous monitoring of the business relationship, including scrutiny of the operations carried out throughout that relationship in order to ensure that they match the knowledge that the obligated subject has of the client and their business and risk profile, including the source of funds, and to ensure that the documents, data, and information available are up to date.”

For its part, Royal Decree 304/2014, of May 5, which approves the Regulation of Law 10/2010, of April 28, on the prevention of money laundering and the financing of terrorism, which develops the LPBCFT, establishes:

“Article 10. Purpose and nature of the business relationship.

1. The obligated subjects shall obtain information from their clients in order to understand the nature of their professional or business activity. The activity declared by the client shall be recorded by the obligated subject prior to the commencement of the business relationship.

2. The obligated subjects shall verify the activities declared by the clients in the following cases:

a) When the client or the business relationship presents risks above average, by regulatory provision or because this is inferred from the risk analysis of the obligated subject.

b) When monitoring the business relationship reveals that the client's active or passive operations do not correspond with their declared activity or with their operational background.

3. The actions to verify the declared professional or business activity shall be graduated according to the risk and shall be carried out through documentation provided by the client, or through obtaining information from reliable independent sources. Likewise, the obligated subjects may verify the professional or business activity of clients through on-site visits to the offices, warehouses, or premises declared by the client as places where they carry out their commercial activity, documenting in writing the result of such visits.

(...)

Article 11. Continuous monitoring of the business relationship.

1. The obligated subjects shall scrutinize the operations carried out throughout the business relationship in order to ensure that they match the professional or business activity of the client and their operational background. The obligated subjects shall increase monitoring when they perceive risks above average by regulatory provision or because this is inferred from the risk analysis of the obligated subject.

(...)

2. The obligated subjects shall periodically carry out review processes to ensure that the documents, data, and information obtained as a result of the application of due diligence measures remain updated and valid.

(...)” (the underlining is ours)

In accordance with the aforementioned regulations, the processing carried out by the banking entity consists of, on the one hand, obtaining information from clients in the terms specified in the LPBCFT and, on the other hand, adopting measures aimed at reasonably verifying the truthfulness of such information.

Thus, it is true that the sectoral regulations determine the obligation to verify the professional and business activities of the subjects with whom it intends to engage.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/26

business. However, not foreseeing that this must be done in a specific manner, it is the data controller (in this case, CAIXABANK) who must decide such verification procedure, which must comply with the regulations on the protection of personal data.

The agreement signed with the TGSS regarding the transfer of information, to which CAIXABANK adhered on (...), in order to facilitate compliance with anti-money laundering regulations for credit institutions, through a mechanized computer procedure that allows for a daily process of data requests by financial entities and transmission of information by the TGSS, could be an adequate mechanism for fulfilling its obligations but not necessarily the only one.

In clause six and in Annex III of the Agreement between the General Treasury of the Social Security, the Spanish Banking Association, the Spanish Confederation of Savings Banks, and the National Union of Credit Cooperatives, regarding the transfer of information, to which CAIXABANK refers in its writings, it is stated that the interested party must consent for the banking entity to verify personal data with the TGSS, and it is indeed included, the clause by which explicit consent can be given to verify the information.

But while this is the way in which the agreement considers that consent must be requested for the purpose of allowing verification in the systems of the TGSS, this is not the only way to verify personal data, in the terms previously mentioned in the LPCBCFT and its implementing regulation.

The regulations do not establish the obligation to verify personal data information with the TGSS, but rather the client provides it, and subsequently, taking into account the different level of risk, there is a general obligation to establish and apply verification procedures for the activities declared by clients.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/26

Therefore, in order to consult personal data with the TGSS, since the Law does not impose this route on banking entities nor does it constitute a legal obligation to consult the TGSS, for the purpose of verifying the personal data information provided by the claimant, it would be necessary to obtain the consent of the interested party, not to impose the use of such a mechanism, and always conditioned to the specific cases in which the regulation requires such verification.

In this regard, Article 4.11 of the GDPR establishes that the "consent of the interested party" is "any

manifestation of will that is free, specific, informed, and unequivocal by which the interested party accepts, either by a declaration or a clear affirmative action, the processing of personal data concerning them."

Consent is understood as a clear affirmative act that reflects a manifestation of free, specific, informed, and unequivocal will of the interested party to accept the processing of personal data concerning them, provided with sufficient guarantees to demonstrate that the interested party is aware of the fact that they are giving their consent and to what extent they do so.

Likewise, it must be given for all processing activities carried out for the same or similar purposes, so that when the processing has multiple purposes, consent must be given for all of them in a specific and unequivocal manner. In this respect, the lawfulness of the processing requires that the interested party be informed about the purposes for which the data are intended (informed consent).

Furthermore, consent must be given freely. Consent is understood not to be free when the interested party does not have a genuine or free choice or cannot refuse or withdraw their consent without suffering any detriment, or when the fulfillment of a contract or provision of a service is dependent on consent, even if it is not necessary for such fulfillment. This occurs when consent is included as a non-negotiable part of the general conditions.

Without these conditions, the consent given by the interested party would not determine control over their personal data and its destination.

On the other hand, the European Data Protection Board in the document "Guidelines 05/2020 on Consent under Regulation 2016/679," which updates the guidelines on consent adopted by the Article 29 Working Party on 28/11/2017, revised and approved on 10/04/2018, refers to this and indicates that:

"3. In general, consent can only be an appropriate legal basis if it offers the interested party control and a real ability to choose regarding whether they wish to accept or reject the offered conditions or reject them without suffering any detriment. When requesting consent, the data controller has the obligation to assess whether such consent will meet all the requirements for obtaining valid consent. If obtained in full compliance with the GDPR, consent is a tool that gives interested parties control over whether the personal data concerning them will be processed or not. If not, the control of the interested party will be merely illusory, and consent will not be a legal basis."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/26

valid for processing, which will render such processing activity unlawful.

These guidelines continue to state:

"13. The term 'free' implies real choice and control by the data subjects. As a general rule, the GDPR establishes that if the subject is not truly free to choose, feels compelled to give their consent, or will suffer negative consequences if they do not give it, then the consent cannot be considered valid. If consent is included as a non-negotiable part of the general terms, it is assumed that it has not been given freely. Consequently, consent will not be considered to have been given freely if the data subject cannot refuse or withdraw their consent without detriment."

They also indicate:

"62. The GDPR reinforces the requirement that consent must be informed. In accordance with Article 5 of the GDPR, the requirement for transparency is one of the fundamental principles, closely related to the principles of fairness and lawfulness. Providing information to data subjects before obtaining their consent is essential for them to make informed decisions, understand what they are authorizing, and, for example, exercise their right to withdraw consent. If the controller does not provide accessible information, user control will be illusory, and consent will not constitute a valid basis for data processing.

63. If the requirements regarding informed consent are not met, the consent will not be valid, and the controller may be in breach of Article 6 of the GDPR.

64. For consent to be informed, it is necessary to communicate to the data subject certain elements

that are crucial for making a choice. Therefore, the EDPB believes that at least the following information is required to obtain valid consent:

- i the identity of the data controller.
- ii the purpose of each of the processing operations for which consent is sought.
- iii what (type of) data will be collected and used.
- iv the existence of the right to withdraw consent.
- v information about the use of data for automated decision-making in accordance with Article 22(2)(c), where relevant, and
- vi information about the potential risks of data transfers due to the absence of an adequacy decision or appropriate safeguards, as described in Article 46.”

In the present case, from CAIXABANK's adherence to the agreement (...) until the modifications of the procedure in 2023:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/26

- Consent cannot be considered free because with the signing of the framework contract or model 5433, all clients are required to have their personal data verified through consultation with the TGSS. This absolutely limits the ability of such individuals to decide whether they want CAIXABANK to carry out such verification of personal data through consultation with the TGSS, as it is not mandatory, as stated.

- Furthermore, consent must be given for all processing activities carried out for the same or similar purposes, so that when processing has multiple purposes, consent must be given for all of them in a specific and unequivocal manner. However, in this case, it cannot be considered specific and unequivocal since the mechanisms for obtaining consent from CAIXABANK clients for it to consult their personal data with the TGSS, through the framework contract model and the model, are already pre-established, just like a pre-checked box.

- Consent cannot be considered informed because:

a) The framework contract, which new clients signed, indicated, on one hand, that “they give their express consent to Caixabank so that in their name we can request such information from the General Treasury of the Social Security,” although in section 4.5 of such contract it does not include such processing within the section related to “Processing based on consent.”

b) The model 5433, which existing clients had to sign for the update of their personal data, stated that “The declarant states that they have been informed by CaixaBank that the current legislation on the prevention of money laundering obliges banking entities to obtain from their clients information about their economic activity and to carry out a verification of the same. For this exclusive purpose of verifying the information provided, they give their express consent to CaixaBank so that in their name it can request such information from the General Treasury of the Social Security.” This information must be added to what these individuals already had when they signed the aforementioned framework contract. The information provided could cause confusion to an average citizen because:

- It did not allow for express consent, but rather the consent was reflected in a standard clause of the models to which they were obliged to adhere.

- Such clause referred to the legal obligations regarding LPBCFT.

- In the information provided about that processing of personal data, since such processing was not expressly included in the processing whose legal basis was consent, it could be directly related to the processing concerning the legal obligation regarding LPBCFT, a regulation to which the clause of the models referred.

Therefore, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement, attributable to the claimed party, for violation of Article 6.1 of the GDPR in relation to the procedure established by CAIXABANK to collect the consent of its clients to verify certain personal data related to LPBCFT before the TGSS.

IV

Classification of the infringement

The infringement attributed to CAIXABANK is classified under Article 83.5 a) of the GDPR, which considers that the infringement of “the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9” is subject to sanction, in accordance with paragraph 5 of the aforementioned Article 83 of the cited Regulation, “with administrative fines of up to €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount.”

The LOPDGDD in its Article 71, Infringements, states that: “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

And in its Article 72, it considers for the purposes of prescription that they are: “Very serious infringements:

1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe in three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679.

(...).

V

Proposal for sanction

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for in Article 58, paragraph 2, letters a) to h) and j).

When deciding on the imposition of an administrative fine and its amount in each individual case, due consideration shall be given:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/26

a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;

a) the intent or negligence in the infringement;

b) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the data subjects;

c) the degree of responsibility of the data controller or processor, considering the technical or organizational measures they have implemented pursuant to Articles 25 and 32;

d) any previous infringement committed by the data controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate any possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58(2) have been previously ordered against the data controller or processor in relation to the same matter, compliance with those measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42; and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

In relation to point k) of Article 83.2 of the GDPR, the LOPDGD, in its Article 76, “Sanctions and corrective measures,” establishes that:

“2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The ongoing nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

According to the transcribed provisions, and without prejudice to the outcome of the instruction of the procedure, for the purpose of determining the amount of the fine to be imposed in this case for the infringement classified in Article 83.5 of the GDPR for which the respondent is held responsible, an initial assessment considers the following concurrent factors:

As aggravating circumstances:

- The nature, severity, and duration of the infringement (Article 83.2.a) of the GDPR), as the facts revealed affected all its clients from CAIXABANK's adherence to the agreement with the TGSS (...) until February 2023. Specifically, it affected, from December 7, 2021, until the dates previously indicated when the KYC processes for the year 2023 were initiated:

(...)

- The intent or negligence in the infringement (Article 83.2.b) of the GDPR). CAIXABANK adhered to the agreement with the TGSS (...), an agreement that imposes on the financial entity, in its sixth clause, the requirement to obtain the corresponding express authorization, signed by the data subject. However, they required consent in an adhesion clause without a real possibility of consenting, being fully aware of the requirements of the agreement signed with the TGSS.

In this regard, the SAN of October 17, 2007 (rec. 63/2006) is very illustrative, which indicates that “...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on the rigor and exquisite care to comply with the legal provisions in this regard.”

- The circumstance of Article 83.2.e) GDPR: “Any previous infringement committed by the data controller or processor.”

Recital 148 of the GDPR states “In order to reinforce the application of the rules of this Regulation [...]” and indicates in this regard that “Special attention must nevertheless be paid to the nature, severity, and duration of the infringement, to its intentional nature [...] or to any relevant infringement [...]”.

Thus, according to point e) of Article 83.2. GDPR, in determining the amount of the administrative fine, all previous infringements of the data controller or processor must be assessed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/26

to calibrate the unlawfulness of the analyzed conduct or the culpability of the infringing subject. Furthermore, a correct interpretation of the provision of Article 83.2.e) of the GDPR cannot overlook the purpose pursued by the regulation: to determine the amount of the administrative fine in the individual case presented, always ensuring that the sanction is proportional, effective, and deterrent. There are numerous sanctioning procedures processed by the AEPD in which the respondent has been sanctioned for the infringement of Article 6.1 of the GDPR:

- i. PS/00477/2019. Resolution issued on January 5, 2021, in which a fine of 2,000,000 euros was imposed for Articles 13 and 14 of the GDPR and 4,000,000 euros for Article 6 of the GDPR. The facts concerned the transfer of data to group companies.
 - ii. PS/00500/2020. Resolution issued on September 22, 2021, in which a fine of 3,000,000 euros was imposed. The facts concerned the procedures for obtaining consent to create profiles for commercial purposes.
 - iii. PS/00226/2020. Resolution issued on February 4, 2022, in which a fine of 2,000,000 euros was imposed for Article 6 in relation to Article 7.4 of the GDPR and 100,000 euros for Article 6.1. The facts concerned the procedure for collecting consent and the existence of pre-checked consents.
 - iv. PS/00254/2023. Resolution issued on October 19, 2023, in which a fine of 200,000 euros was imposed. The facts concerned the maintenance of personal data in the credit information file when the debt had been sold to a third party. CAIXABANK availed itself of the two reductions provided.
- The activity of the allegedly infringing entity is linked to the processing of data of both clients and third parties. In the activity of the respondent entity, the processing of personal data of its clients is essential, so given the volume of this activity, the significance of this activity subject to the present claim is very high (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

Considering the factors presented, for the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure and without prejudice to what results from the instruction, taking into account the circumstances of the case and the criteria established by Article 83.2 of the GDPR regarding the committed infringement, it allows for an initial fine of 2,000,000 euros.

VI

Adoption of measures

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/26

If the infringement is confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, under which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

In such a case, in the resolution that is adopted, this Agency may require the responsible party to, within the determined timeframe:

Adequately inform and obtain consent, in the terms of the GDPR, from the clients of the entity who, from CAIXABANK's (...) adherence to the agreement with the TGSS and until the modifications of the process in 2023, had signed a framework contract and/or a model 5433 (Declaration/Modification of data for the business relationship) and who had not been adequately informed and/or whose consent had not been obtained, in the terms set forth in this initiation agreement, in relation to the verification of personal data before the TGSS in the terms of the LPBCFT.

It is noted that failure to comply with the possible order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in Articles 83.5 and 83.6, which could motivate

such conduct to open a further administrative sanctioning procedure.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,
IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against CAIXABANK, S.A. with NIF A08663619, for the alleged infringement of Article 6.1 of the GDPR, classified in Article 83.5 of the GDPR.

SECOND: TO APPOINT R.R.R. as the instructor and S.S.S. as the secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaint filed by the complainant and its documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the proceedings prior to the initiation of the present sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be, for the alleged infringement of Article 6.1 of the GDPR, classified in Article 83.5 of that regulation, an administrative fine of amount

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/26

TWO MILLION EUROS (2,000,000.00 €), without prejudice to what results from the instruction.

FIFTH: NOTIFY this agreement to CAIXABANK, S.A. with NIF A08663619, granting it a period of ten working days to submit allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the file number indicated in the heading of this document.

If no allegations are made regarding this initial agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of the LPACAP.

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initial agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be established at ONE MILLION SIX HUNDRED THOUSAND EUROS (1,600,000.00 €), resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be established at ONE MILLION SIX HUNDRED THOUSAND EUROS (1,600,000.00 €) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to formulate allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction would be established at ONE MILLION TWO HUNDRED THOUSAND EUROS (1,200,000.00 €).

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction.

In the event that it opts to proceed with the voluntary payment of any of the amounts indicated above (1,600,000.00 € or 1,200,000.00 €), it must make the payment by depositing it into account No. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which it is entitled.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
24/26

Furthermore, you must send the proof of payment to the General Inspection Subdirectorate to continue with the procedure in accordance with the amount paid.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. If this period elapses without a resolution being issued and notified, it will expire, and consequently, the proceedings will be archived; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

Mar España Martí
Director of the Spanish Agency for Data Protection

>>

SECOND: On March 28, 2024, the respondent has proceeded to pay the fine in the amount of 1,200,000 euros, making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the waiver of any action or administrative appeal against the fine and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement.

FOURTH: In the aforementioned Initiation Agreement transcribed earlier, it was indicated that if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the cited Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”.

Having received a written communication from CAIXABANK, S.A. informing that it has adopted the necessary measures to prevent the reoccurrence of the facts leading to the infringement, this Agency acknowledges receipt of the same, without this declaration implying any pronouncement on the regularity or legality of the measures adopted.

It is warned about the provisions of Article 5.2 of the GDPR, which establishes the principle of proactive responsibility when it states that “The controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it.” This principle refers to the obligation that falls on the controller not only to design, implement, and observe the appropriate legal, technical, and organizational measures to ensure that data processing is in accordance with the regulations but also to remain actively vigilant throughout the entire lifecycle of the processing to ensure that such compliance is correct, and to be able to demonstrate it.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

25/26
LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading “Termination in sanctioning procedures” provides as follows:

“1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely pecuniary or when a pecuniary sanction and another non-pecuniary sanction can be imposed but the latter has been justified as inappropriate, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely pecuniary, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the initiation notification.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/26

of the procedure and its effectiveness will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative pathway against the sanction.

The percentage of reduction provided in this section may be increased by regulation.”

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202300944, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO NOTIFY this resolution to CAIXABANK, S.A.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative pathway as stipulated by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1219-21112023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es